

ENTERPRISE DATA GOVERNANCE & FINANCIAL COMPLIANCE AGREEMENT

Master Services Agreement - Compliance Addendum

Party A (Data Controller):	GlobalFinTech Corporation Ltd.
Party B (Data Processor):	CloudServe Technologies Inc.
Contract Reference:	GFC-COMP-2026-0089
Effective Date:	1st January 2026
Review Date:	31st December 2026
Classification:	CONFIDENTIAL
Version:	3.2 (Final)
Governing Law:	England and Wales

REGULATORY SCOPE

This agreement covers compliance obligations under GDPR, SOX, HIPAA, PCI-DSS, and Insurance/Financial Services regulations applicable to GlobalFinTech Corp.

PART I DATA PROTECTION & GDPR COMPLIANCE

1.1 Lawful Basis for Processing Personal Data

GlobalFinTech Corporation processes personal data strictly in accordance with Article 6 of the General Data Protection Regulation (EU) 2016/679. The primary legal bases relied upon are: (a) contractual necessity under Article 6(1)(b) for the performance of services requested by data subjects; (b) compliance with legal obligations under Article 6(1)(c) including anti-money laundering and tax reporting requirements; and (c) legitimate interests under Article 6(1)(f) for fraud prevention and network security purposes. A Legitimate Interests Assessment (LIA) has been conducted and documented for all processing activities relying on legitimate interests. Consent is obtained separately where required for marketing communications.

1.2 Data Retention and Deletion Policy

The Company retains personal data for periods determined by the original purpose of collection. Customer transaction records are retained for 7 years to satisfy financial regulatory requirements. Marketing preference data is retained for 2 years from last interaction or until consent withdrawal. Employee records are retained for the duration of employment plus 6 years. However, the Company acknowledges that a comprehensive, documented data retention schedule covering all data categories has not yet been formally approved by the Data Protection Officer. Interim retention periods are applied operationally but the formal policy document remains in draft. Automated deletion workflows have been implemented for transactional data only.

1.3 Data Subject Rights - Access and Erasure

Data subjects may exercise their rights under Chapter III of GDPR including the right of access (Article 15), right to rectification (Article 16), right to erasure (Article 17), right to restriction of processing (Article 18), and right to data portability (Article 20). Requests must be submitted via our Data Subject Request portal at privacy.globalfintech.com or in writing to the Data Protection Officer. All requests are acknowledged within 5 business days and completed within 30 days of receipt. The DPO maintains a register of all DSARs received, including outcome and timescales. Identity verification is performed before processing any request to prevent unauthorised disclosure.

1.4 Personal Data Breach Notification Procedure

In the event of a personal data breach as defined under Article 4(12) of GDPR, the Company will assess the risk to data subjects and notify the relevant supervisory authority (ICO in the UK) within 72 hours of becoming aware of the breach where the breach is likely to result in a risk to the rights and freedoms of natural persons, in accordance with Article 33. Where the breach is likely to result in a high risk, affected data subjects will be notified without undue delay under Article 34. The Company maintains a documented Incident Response Plan (IRP-2026-003) reviewed annually by the CISO. A Data Breach Response Team is on call 24/7. Tabletop exercises are conducted bi-annually to test the 72-hour notification capability.

1.5 Third Party Data Processor Agreements

The Company engages 47 third-party data processors across cloud infrastructure, analytics, customer support, and payment processing functions. Data Processing Agreements (DPAs) compliant with Article 28 of GDPR have been executed with 39 of these processors. Eight processors, primarily recent onboarding during Q4 2025, do not yet have executed DPAs in place. The legal team has initiated DPA execution with all 8 outstanding processors with a target completion date of Q2 2026. Sub-processor notifications are provided via our privacy notice.

PART II SOX COMPLIANCE & FINANCIAL CONTROLS

2.1 Internal Controls Over Financial Reporting (ICFR)

Management acknowledges that formally documented Internal Controls over Financial Reporting (ICFR) as required under Section 404 of the Sarbanes-Oxley Act have not been comprehensively documented for the current fiscal year. While operational financial controls exist and are applied by the finance team, the formal ICFR framework including control objectives, control activities, risk assessments, and monitoring activities has not been completed. The CFO has engaged an external consultant to develop the ICFR framework with a target completion of Q3 2026. Management accepts this represents a material weakness in the current compliance posture and has communicated this to the Audit Committee. Compensating controls including dual authorisation for payments above GBP 50,000 and monthly reconciliations are in operation.

2.2 Independent Auditor Attestation

The Company's external auditors, Deloitte LLP, have been engaged to conduct the annual statutory audit for the financial year ending 31 December 2025. The audit engagement letter includes the scope for review of internal controls over financial reporting in accordance with AS 2201. However, given the incomplete state of the ICFR documentation noted in section 2.1, the auditor attestation on the effectiveness of internal controls is expected to include qualifications. The previous year's audit (FY2024) received an unqualified opinion. Management is working to resolve the ICFR documentation gaps before the FY2025 audit fieldwork commences in September 2026.

2.3 Financial Record Retention

All financial records, general ledger entries, accounts payable and receivable records, bank reconciliations, audit workpapers, and supporting documentation are retained for a minimum period of 7 years in accordance with Section 802 of the Sarbanes-Oxley Act and applicable HMRC requirements. Records are stored in an encrypted, access-controlled document management system (NetDocuments) with automated retention enforcement. Physical records are stored in a climate-controlled off-site facility managed by Iron Mountain under a records management agreement. Destruction of records before the expiry of the retention period requires written authorisation from the CFO and General Counsel. An annual records retention audit is conducted by Internal Audit.

2.4 Whistleblower Protection Policy

The Company operates a confidential whistleblowing hotline managed by an independent third party (Expolink Europe Ltd) available 24 hours a day, 7 days a week. Employees, contractors, and suppliers may report concerns anonymously. The policy explicitly prohibits retaliation against individuals who report concerns in good faith, and any retaliation is treated as gross misconduct. Reports are investigated by the Audit Committee with independence from line management. The policy is reviewed annually and all employees receive mandatory training during onboarding and annually thereafter. The Company's whistleblowing policy complies with the UK Public Interest Disclosure Act 1998 and applicable US Dodd-Frank provisions.

PART III HIPAA COMPLIANCE - PROTECTED HEALTH INFORMATION

3.1 PHI Access Controls

The Company handles Protected Health Information (PHI) solely in connection with its employee benefits administration, occupational health services, and group health insurance programmes. Access to PHI is strictly limited to authorised HR Benefits personnel, occupational health practitioners, and designated payroll staff requiring access for benefits deductions. Role-based access controls are implemented within the HR information system (Workday). Access rights are reviewed quarterly and revoked immediately upon change of role or termination. Privileged access management (PAM) controls are applied to system administrators. All PHI access is logged and monitored by the Information Security team.

3.2 Encryption of PHI in Transit and at Rest

All PHI transmitted electronically is encrypted using TLS 1.3 or higher. PHI stored in the Workday HR system and associated document management systems is encrypted at rest using AES-256. Portable devices that may contain PHI are subject to full-disk encryption enforced by MDM policy. Email transmission of PHI is prohibited except via the Company's encrypted email gateway (Proofpoint Encryption). USB and removable media containing PHI are prohibited under the Company's acceptable use policy. Annual encryption key rotation is performed for data-at-rest.

3.3 HIPAA Breach Notification

In the event of a breach of unsecured PHI, the Company will notify affected individuals without unreasonable delay and within 60 days of discovery of the breach, in accordance with 45 CFR Part 164 Subpart D. Notification to the Secretary of HHS will be provided simultaneously. For breaches affecting 500 or more individuals in a state, prominent media notice will be provided. The Company's Incident Response Plan includes a dedicated PHI breach notification workflow with assigned responsibilities and template notifications. Breach risk assessments are conducted using the four-factor test specified in the HIPAA Breach Notification Rule.

3.4 PHI Audit Logging

The Company acknowledges that comprehensive audit logging for all systems containing PHI has not been fully implemented. Audit logs are in place for the primary Workday HR system, however three legacy occupational health record systems acquired through the 2023 merger with MedCorp Solutions do not currently generate HIPAA-compliant audit logs. A project to replace these legacy systems with a HIPAA-compliant platform is underway with a target completion of Q4 2026. In the interim, manual access reviews are conducted monthly for these legacy systems.

3.5 Business Associate Agreements

Business Associate Agreements (BAAs) have been executed with the Company's primary benefits administration vendor (Mercer) and occupational health provider (Bupa Occupational Health). However, BAAs have not been executed with two recently onboarded employee assistance programme providers who may have access to PHI. The procurement team has been instructed to obtain signed BAAs from these vendors within 30 days. No PHI has been transmitted to these vendors pending BAA execution. The Company maintains a register of all Business Associates updated quarterly.

PART IV PCI-DSS COMPLIANCE - PAYMENT CARD DATA SECURITY

4.1 Protection of Stored Cardholder Data

GlobalFinTech does not store Primary Account Numbers (PAN) or full magnetic stripe data within its own infrastructure. All payment card transactions are processed exclusively through Stripe Payments Europe Ltd, a PCI-DSS Level 1 certified payment service provider. Tokenisation is used for all recurring billing arrangements, with tokens stored in Stripe's vault. The Company's systems receive only the last four digits of the card number and the card brand for display purposes. No cardholder data is transmitted through or stored in the Company's CRM, ERP, or data warehouse systems. Annual confirmation of Stripe's PCI-DSS Level 1 certification is obtained and retained on file.

4.2 Access Control to Cardholder Data Environment

Access to the cardholder data environment (CDE) is restricted exclusively to staff whose job roles require such access, in accordance with the principle of least privilege. Currently, access rights to payment processing systems have not been formally reviewed following the organisational restructuring in Q1 2026. Twelve individuals retain access rights to payment system administration consoles that may no longer be required given their new roles. A formal access review has been scheduled for completion within 45 days. In the interim, enhanced monitoring of these accounts has been implemented via the SIEM platform.

4.3 Firewall and Network Segmentation

The cardholder data environment is segregated from the corporate network and public internet using a dedicated next-generation firewall (Palo Alto Networks PA-5220) with application-aware filtering. Network segmentation is enforced through VLANs and micro-segmentation policies. Firewall rulesets are reviewed quarterly by the Network Security team and annually by external penetration testers. All changes to firewall rules follow the Change Advisory Board process with dual approval. Inbound connections to the CDE are restricted to specific IP ranges for authorised payment processor connections only. DMZ architecture is maintained between internet facing systems and the CDE.

4.4 Vulnerability Management and Security Testing

The Company conducts quarterly internal and external vulnerability scans of all systems in scope for PCI-DSS using Qualys Enterprise. Critical and high vulnerabilities are remediated within 30 and 60 days respectively. Annual penetration testing is conducted by an approved scanning vendor (ASV), most recently completed March 2026 with no critical findings. Web application security testing of payment-related interfaces is conducted annually using OWASP methodology. A bug bounty programme is in operation for responsible disclosure of payment-related vulnerabilities. Patch management is automated for operating systems and middleware.

PART V INSURANCE & FINANCIAL SERVICES COMPLIANCE

5.1 Policy Terms and Conditions Disclosure

All insurance product terms, conditions, exclusions, limitations, and premium calculation methodologies are disclosed to policyholders at the point of sale in accordance with the Financial Conduct Authority's Insurance: Conduct of Business Sourcebook (ICOBS). Policy documents are provided in plain English with a summary of key features and exclusions prominently displayed. Pre-contractual information including the Insurance Product Information Document (IPID) is provided for all general insurance products. Customer communications are reviewed annually for clarity and accessibility. A fair and clear communications policy is maintained and training provided to all customer-facing staff.

5.2 Claims Processing Timeline

The Company acknowledges that its current claims processing performance does not consistently meet regulatory expectations. Claims are acknowledged within 5 business days of receipt, which exceeds the 10 business day acknowledgement standard. However, average claims resolution time currently stands at 52 business days, significantly exceeding the 30-day resolution target. The claims backlog has increased due to a 34% volume increase in Q1 2026 and resourcing constraints. An emergency claims processing improvement programme has been initiated including automation of standard claims via AI triage. Target resolution time of 30 days is expected to be achieved by Q3 2026. FCA has been notified of the performance shortfall.

5.3 Anti-Money Laundering and KYC Compliance

The Company operates a risk-based AML programme compliant with the Money Laundering, Terrorist Financing and Transfer of Funds Regulations 2017. Customer Due Diligence (CDD) is performed for all new customers using automated identity verification (Onfido) integrated with sanctions screening (Refinitiv World-Check). Enhanced Due Diligence (EDD) is applied to high-risk customers including Politically Exposed Persons (PEPs) and customers from high-risk jurisdictions. Ongoing monitoring of customer transactions is performed using a rule-based transaction monitoring system with thresholds reviewed annually by the MLRO. Suspicious activity reports are filed with the National Crime Agency as required. Annual AML training is mandatory for all staff.

5.4 Capital Adequacy and Solvency Requirements

The Company maintains regulatory capital in accordance with the Solvency II Directive as implemented in UK law post-Brexit. The Solvency Capital Requirement (SCR) coverage ratio as at 31 December 2025 was 187%, significantly above the 100% minimum requirement. The Minimum Capital Requirement (MCR) coverage ratio was 312%. The Company produces quarterly Quantitative Reporting Templates (QRTs) submitted to the Prudential Regulation Authority. The Own Risk and Solvency Assessment (ORSA) is conducted annually and reviewed by the Board Risk Committee. Capital management policy is reviewed annually with stress testing conducted semi-annually to assess resilience under adverse scenarios.

PART VI EXECUTION AND SIGNATURES

This Agreement constitutes the entire agreement between the parties with respect to the subject matter herein and supersedes all prior agreements, representations, and understandings. Amendments to this Agreement must be in writing and signed by authorised representatives of both parties. This Agreement shall be governed by and construed in accordance with the laws of England and Wales, and the parties submit to the exclusive jurisdiction of the English courts.

FOR GLOBALFINTECH CORPORATION LTD.

FOR CLOUDSERVE TECHNOLOGIES INC.

Authorised Signatory

Name: _____

Title: _____

Date: _____

Authorised Signatory

Name: _____

Title: _____

Date: _____